

FutureProof EPM

Stakeholder-Gated Build Plan

Seven Stakeholder Gates · ~30 Weeks to Pilot · ~AUD 285k Build · ~AUD 700k Capital Ask

For Stakeholder Distribution — April 2026

Document	Stakeholder-Gated Build Plan v1.0
Prepared for	Stakeholder meeting (Tuesday pack)
Team	2 people, AI-first (CTO + BA/Programmer)
Duration	~30 weeks to pilot-live + Post-Live phase
Budget (build)	AUD 285k with contingency (legal separate)
Run-rate (post-live)	~AUD 325–360k / year
Capital ask	AUD 700k (build + 12 mo post-live + migration reserve + buffer)
Infrastructure	Fly.io Sydney (pilot) → AWS ap-southeast-2 (triggered, not time-based)

Executive Summary

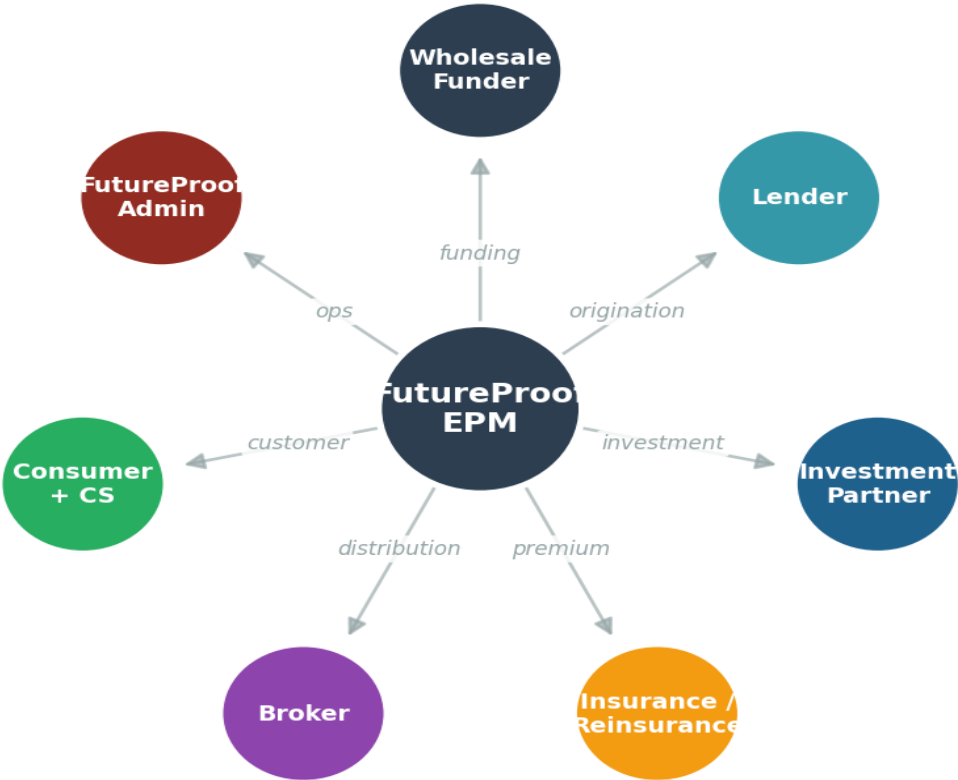
An Australian-first Equity Preservation Mortgage, built to pilot-live in **thirty weeks** by a two-person AI-first team and gated, one stakeholder at a time, by the people whose money and reputation sit on the platform: the wholesale funder, the lender, the investment partner, the reinsurer, the broker, the consumer. Every stakeholder signs their own scope, watches their own tests go green, and countersigns their own gate before we move on. Nothing ships on trust.

The capital ask is **AUD 700k**: a **AUD 285k** build through to pilot, a funded Year-1 Post-Live runway, a named reserve for the Fly.io → AWS migration when a counterparty first demands it, and an operational contingency buffer. External legal spend (contracts, PDS, broker accreditation, funder agreements, AFSL / ACL work) is funded from a separate legal budget and is not included in this ask. The output is a launched product, countersigned integration reports from every counterparty, a clean pen test, a filed PDS, and a live pilot cohort — not a prototype.

Headline points

- **Stakeholder-gated ceremony.** Formal scope → tests → build loop per stakeholder group; binary pass/fail at each gate. No stakeholder is surprised at pilot — each has signed their own milestone.
- **Funding-first sequencing.** Supply side (funder, lender, investment partner, reinsurer) gated before demand side (broker, consumer). The capital table is proven before the first customer walks in.
- **Investment partner has a Plan-B.** BlackRock is the working assumption; the Investment Partner Interface abstraction allows a domestic managed-account provider to be substituted on ~4 weeks of work if needed.
- **AI-first with guardrails.** Claude writes the first draft of most code, tests and briefs; acceptance tests, deploy gates (G1–G6) and contract / model-fidelity tests contain AI weaknesses. No AI output bypasses the gate.
- **AI cuts ~AUD 285k / yr from back-office run-rate** across finance, operations, customer support and marketing — the reason Post-Live is a two-person team rather than five.
- **Explicit Post-Live phase.** Release cadence, incident model, security re-certification, model recalibration and an event-triggered infrastructure migration are all named and budgeted — day one, not day ninety.
- **Fly.io verdict.** Fit for pilot; migrate to AWS Sydney when the first counterparty due-diligence questionnaire asks for IRAP or APRA CPS 234 — not before, not later.

Stakeholder Map — Seven Groups, One Platform



1. Team & Working Model

Two people. Both can code.

- **CTO** — architecture, CI/CD, deploy gates, on-call, partner API integrations. Owns the release branch.
- **BA / Programmer** — stakeholder management, requirements briefs, acceptance-test authoring, and production-grade code generation via Claude prompts (AI-augmented). The BA is not a note-taker; they ship.

BA working loop

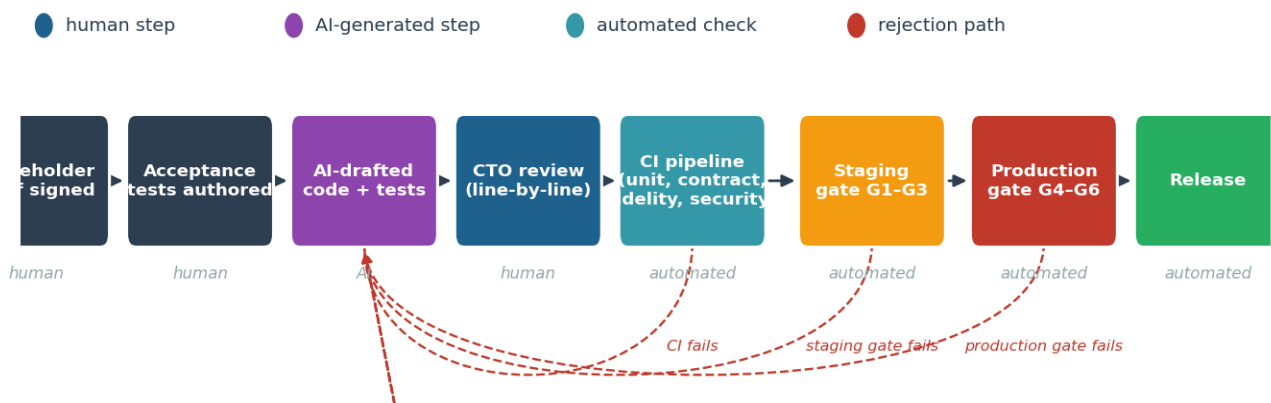
- Meet stakeholder, capture the scope verbally.
- Write the one-page scope brief. Get stakeholder sign-off.
- Convert the brief into executable acceptance tests.
- Drive Claude prompts to generate the implementation against those tests.
- CTO reviews, lands, and promotes through the gate.

Velocity assumption: AI-first 2-person team $\approx 1.8\times$ pre-AI 2-person team. Documented honestly. Not $5\times$. Not $10\times$. The BA's bottleneck is stakeholder-facing work; AI helps, it does not replace.

1.1 AI-first — with explicit guardrails

We take an AI-first approach to delivery. Claude drafts most code, tests and stakeholder briefs. We also accept openly that AI is not perfect — it hallucinates APIs, drifts on long context, and produces plausible-looking but subtly wrong code in regulated-finance domains. Our delivery process is built to contain those weaknesses rather than pretend they are absent.

PR → Deployment Pipeline: every change, every time



On any red: rework the draft — never the gate.

The pipeline above is how every change ships — AI-drafted or not. Humans set the intent (signed stakeholder brief, authored acceptance tests). AI drafts the implementation. Humans review line-by-line. Automation then enforces the rules: CI runs unit, contract and model-fidelity tests against the locked v14c Optimised actuarial output; staging gates G1–G3 and production gates G4–G6 run on every release. On any red, the rework lands on the draft — never on the gate. That is the whole point: AI buys us throughput per person, not ceremony skipped.

2. Working Commercial Assumptions

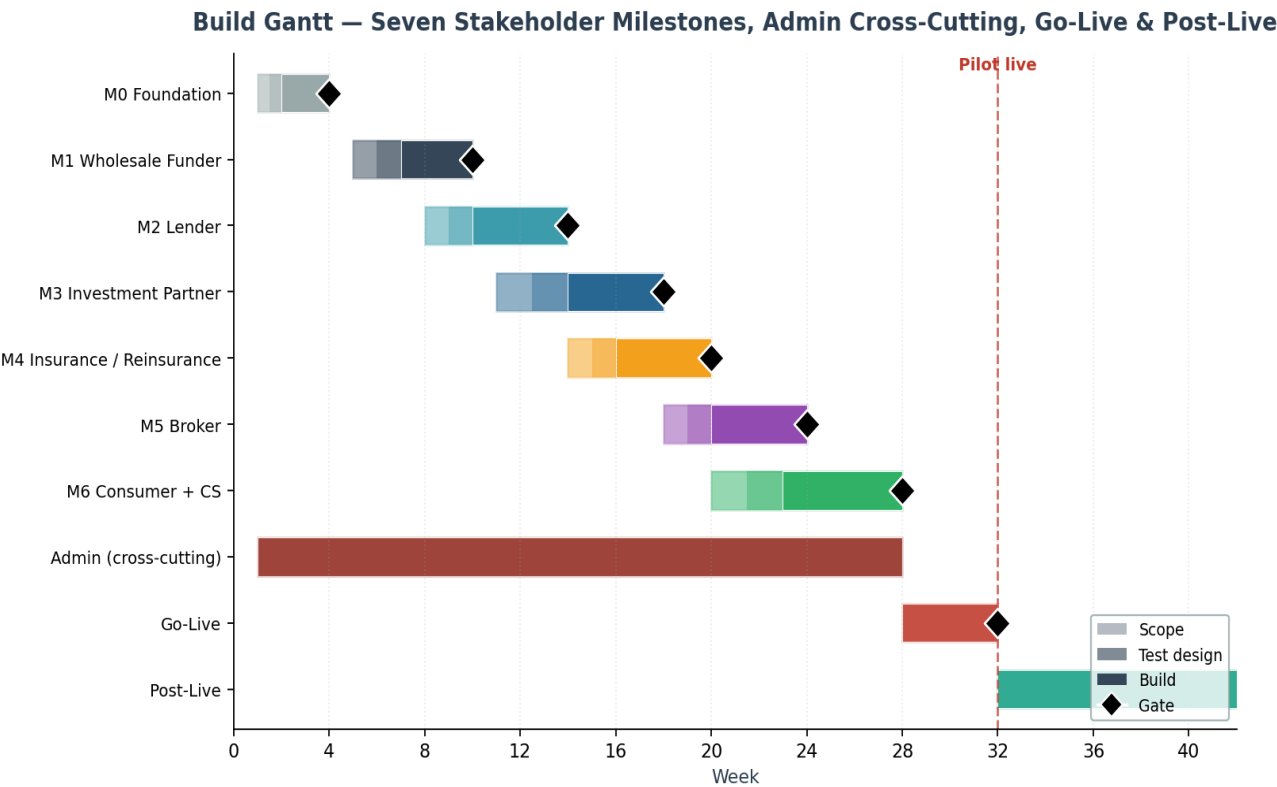
The table below is the planning baseline for each stakeholder group. These are *assumptions*, not commitments — the final number for every line is signed off as part of its milestone scope brief and can move during commercial negotiation. They are published here so the stakeholder reading this plan can see their own economics at a glance rather than discovering them milestone by milestone.

Stakeholder	Assumption	Value	Source / status
Wholesale funder	Wholesale rate	BBSW + 2.5%	Final rate set at M1 gate; range 2.0–3.0%
Wholesale funder	Concentration limit	3% of facility per single mortgage	Funder policy standard
Lender	Origination fee (customer-paid)	1.5% of facility	v14c Optimised input
Lender	Servicing fee	0.25% p.a. of outstanding	Lender commercial standard
Investment Partner	Management fee (BlackRock)	0.15% p.a. on portfolio	iShares indicative; negotiated at M3
Investment Partner	Custody fee	0.05% p.a.	Ditto
LMI	Upfront premium (typical \$750k facility)	~AUD 9,600	v14c: \$4,863 fair + \$4,737 load
Reinsurer	Attachment point	P20 of deficit distribution	v14c actuarial review
Reinsurer	Cession rate above attachment	70%	Working assumption; negotiated at M4
Broker	Upfront commission	0.65% of facility	Industry standard; 2-yr clawback
Broker	Trail commission	0.15% p.a. of outstanding	Industry standard
FutureProof	Retail margin	0.75% p.a. on portfolio	v14c Optimised input
FutureProof	Surplus split (customer share at maturity)	80%	v14c Optimised input

All figures are AUD unless noted. The v14c Optimised actuarial review underpins the FutureProof, LMI, and reinsurer lines; every other line is a working commercial assumption until its milestone gate closes.

3. Milestone Timeline

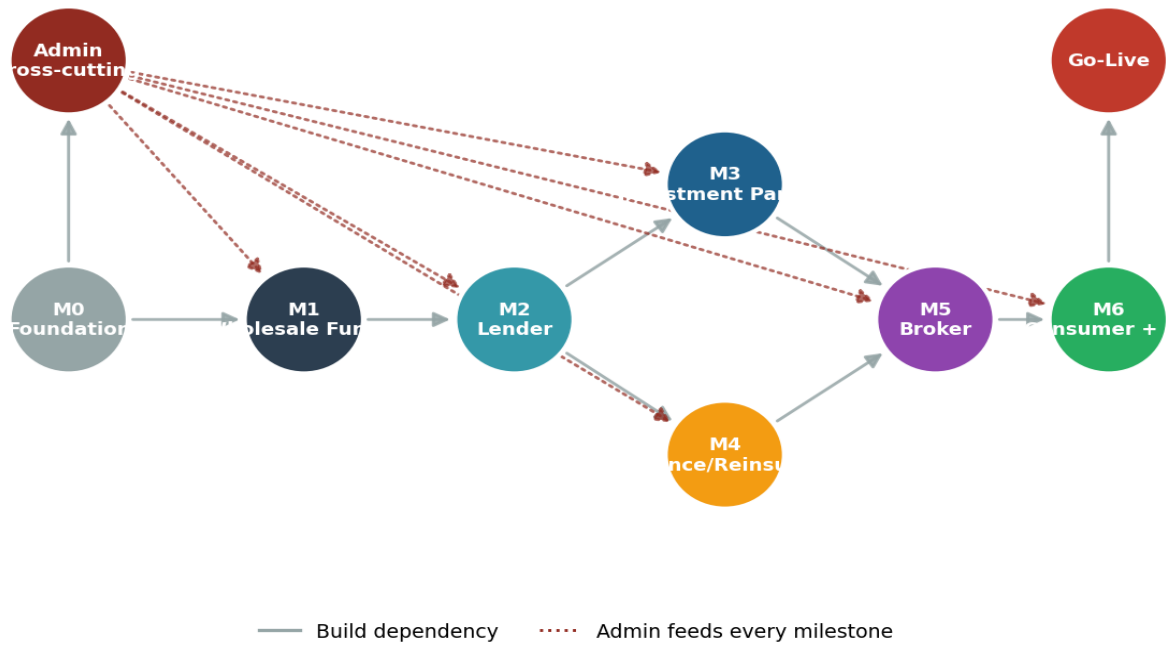
Each milestone runs the scope → test → build loop with a named gate. Admin is cross-cutting: M0 ships the skeleton, every subsequent milestone adds a surface. Go-Live is a four-workstream phase running in parallel.



Dependency graph

Funding-first. Foundation unblocks Wholesale Funder; Wholesale unblocks Lender; Lender unblocks both Investment Partner and Insurance/Reinsurance in parallel; Broker joins after both; Consumer is last. Admin evolves alongside every milestone.

Milestone Dependency Graph



4. Stakeholder Milestones (M0–M6)

For each milestone: stakeholder and sign-off, scope artefacts, tests built first, build deliverable, gate criterion, key risk. Each block below is a single gated loop — scope is signed, tests are authored, build lands against tests, gate closes.

M0 — Foundation (weeks 1–4, ~AUD 22k)

Stakeholder · sign-off. FutureProof internal. Signs off: CTO.

Scope. Harden the platform for production operation. Deliver the stakeholder-gate framework as a first-class piece of code so M1–M6 inherit it. Cloudflare in front of Fly.io Sydney; WAF on; rate limiting on; secrets out of the repo; database with point-in-time recovery; observability (Sentry + health checks + structured logs).

Tests first. Unit and integration suite baselined and grown past 600 tests by end of M0; static security scanning and dependency-vulnerability checks; content-security-policy scan; smoke suite that runs post-deploy against staging.

Build. CI/CD pipeline with five stages (lint / test / model-fidelity / security / artefact); deploy gate framework (G1–G6 as inheritable Actions jobs); Admin skeleton (authenticated, audit-logged, role-based); Fly.io production hardened.

Gate. All five pipeline stages green on main for 14 consecutive days. Staging deploys automatic on merge. Production deploys behind a signed release tag.

Key risk. Under-investing here leaves every subsequent milestone slower. Mitigation: M0 is not compressed; it takes as long as it takes inside the 4-week window.

M1 — Wholesale Funder (weeks 5–10, ~AUD 42k)

Stakeholder · sign-off. Non-bank wholesale funder. Signs off: funding agreement, wholesale rate, drawdown mechanics, reconciliation spec, security controls.

Scope. Define the funding leg end-to-end. What triggers a drawdown, what data is exchanged, how reconciliations run, how disputes escalate, how incident communication works. One-page scope brief written week 5 by the BA and signed by the funder before any code is written.

Tests first. Contract tests (Pact-style) against the funder's API spec; reconciliation fidelity tests (daily files match general ledger); drawdown mechanics (pre-approved limits, concentration rules, haircut logic); tabletop for a funder-side outage.

Build. In-repo fake funder (built first — unblocks M2 and M3); real sandbox integration against the funder's development environment; production connector with TLS-pinned mTLS. Admin surface: funder dashboard (positions, drawdowns, reconciliation state, dispute log).

Gate. Reconciliation matches for 14 consecutive days across fake → sandbox → production, and the funder countersigns the integration test report.

Key risk. No funder signed by week 5. Mitigation: approach 3 funders in parallel from week 1 (the BA's job). Fake-first architecture means build continues in parallel with the commercial negotiation.

M2 — Lender (weeks 8–14, ~AUD 44k)

Stakeholder · sign-off. Retail lender (AFSL holder). Signs off: origination rules, credit decision engine, servicing workflow, lender operational dashboard.

Scope. The rule matrix — who gets approved, under what LVR, with what income, under what property type. The servicing workflow — how statements are produced, how missed payments are handled, how redraws work, how the payment waterfall is triggered. All codified, all acceptance-tested.

Tests first. Rule-matrix tests (one test per approval pathway, one per rejection reason); servicing-workflow tests; AFSL responsible-lending compliance tests; stakeholder-walkthrough with the lender operations team (recorded).

Build. Credit decision engine as a deterministic service; servicing workflow as controllers + background jobs; lender dashboard (applications in flight, approvals, rejections, servicing events).

Gate. Lender-ops signs the rule matrix and the servicing runbook. Tests pass clean. Dependencies: M1 gate-green.

Key risk. Rule matrix churns as the lender discovers edge cases late. Mitigation: tests are authored by the BA during scope; changes require re-sign. Budget three rounds of iteration into the 6 weeks.

M3 — Investment Partner (weeks 11–18, ~AUD 56k)

Stakeholder · sign-off. BlackRock (working assumption — no commercial agreement exists at plan start). Signs off: portfolio construction, rebalancing policy, custody reporting, API contract, sandbox reconciliation.

Scope. The investment leg. What portfolio is constructed ($\approx 70\%$ equity ETF / $\approx 30\%$ fixed income per the actuarial review); who holds custody; how rebalancing is triggered (band-based, time-based, or event-based); how NAV and position reporting is delivered; what data is returned daily and in what format.

Tests first. Contract tests against the Aladdin-adjacent sandbox (portfolio construction, order placement, position and NAV retrieval); iShares pricing feed tests; model-fidelity tests (against v14c golden vectors); stakeholder-walkthrough with BlackRock technical; tabletop for BlackRock-side outage.

Build. Investment connector behind an abstraction (the "Investment Partner Interface"). Concrete implementation against BlackRock; a second implementation against the fake. Admin surface: portfolio positions, NAV trajectory, rebalance events, daily BlackRock reconciliation.

Gate. Sandbox reconciliations clean for 14 consecutive days. BlackRock countersigns the integration test report. Dependencies: M1, M2 gate-green.

Key risk. Primary unknown. BlackRock does not sign in the plan window. Plan B: the Investment Partner Interface abstraction allows substitution of a domestic managed-account provider (Macquarie, Mason Stevens, Netwealth) on ~ 4 weeks of additional work. The abstraction is built regardless of partner choice.

M4 — Insurance / Reinsurance (weeks 14–20, ~AUD 38k)

Stakeholder · sign-off. LMI provider + tail-risk reinsurer. Signs off: policy binding terms, claim notification, premium remittance schedule, attachment point (currently P20 of deficit distribution per v14c actuarial review).

Scope. LMI layer and tail-risk reinsurance layer defined separately. Premium calculation, upfront charge mechanics, claim notification on deficit events at maturity, reinsurer attachment and cession terms.

Tests first. Attachment-point tests (P20 of deficit distribution correctly identified per v14c); premium calculation tests (match the actuarial review's \$9,600 upfront + \$4,863 fair loaded for the Optimised base); policy lifecycle tests; stakeholder walkthrough with LMI + reinsurer.

Build. Policy binding workflow; premium remittance ledger; claim notification pipeline; admin surface: in-force policies, premium history, claim events, reinsurer cession ledger.

Gate. LMI provider and reinsurer both countersign the integration test report. Claim notification tested end-to-end against synthetic deficit cases.

Key risk. Reinsurer capacity at the attachment point. Mitigation: present the v14c Optimised actuarial review to the reinsurer early (week 14) and iterate on attachment if challenged.

M5 — Broker (weeks 18–24, ~AUD 34k)

Stakeholder · sign-off. Pilot brokers. Signs off: broker accreditation process, commission structure, broker portal UX, application handoff mechanics.

Scope. Distribution. Broker accreditation (who can introduce business), commission accrual and payment schedule, portal for broker-lodged applications, handoff mechanics between broker-initiated and direct-initiated applications.

Tests first. Accreditation-flow tests; commission-calculation tests (including clawback rules); portal journey tests; stakeholder walkthrough with pilot brokers.

Build. Broker portal (consistent with the rest of the platform CSS framework); accreditation workflow; commission ledger; broker-scoped admin views.

Gate. Pilot brokers sign the portal acceptance checklist. Commission calculations reconcile against test scenarios. Dependencies: M2, M3 gate-green.

Key risk. Broker accreditation process is regulatorily sensitive. Mitigation: legal review before build (week 18); accreditation rules are acceptance-tested, not free-form.

M6 — Consumer + Customer Support (weeks 20–28, ~AUD 44k)

Stakeholder · sign-off. Pilot customers + CS operator(s). Signs off: application journey, quote calculator, e-sign flow, statements, dispute flow, support case triage.

Scope. The end-to-end customer experience. Application, quote, e-sign, statement view, dispute submission, support case. Plus the CS console: case queue, triage, response templates, escalation to actuary or legal.

Tests first. Customer-journey tests (quote → application → underwriting → contract → e-sign → settlement); accessibility tests (WCAG 2.1 AA); CS console tests; dispute-flow tests; stakeholder walkthrough with pilot customers (5–10) and CS operators.

Build. Customer application surface; quote calculator (using the locked v14c Optimised model); e-sign integration; statement renderer; dispute and support case flows; CS console.

Gate. 10 pilot customer intents successfully completed through the journey in staging. Pilot CS operator signs the console acceptance checklist. Dependencies: M1–M5 gate-green.

Key risk. E-sign and ID verification vendor integration. Mitigation: vendor selection in M0; vendor APIs wrapped behind a thin abstraction to allow substitution.

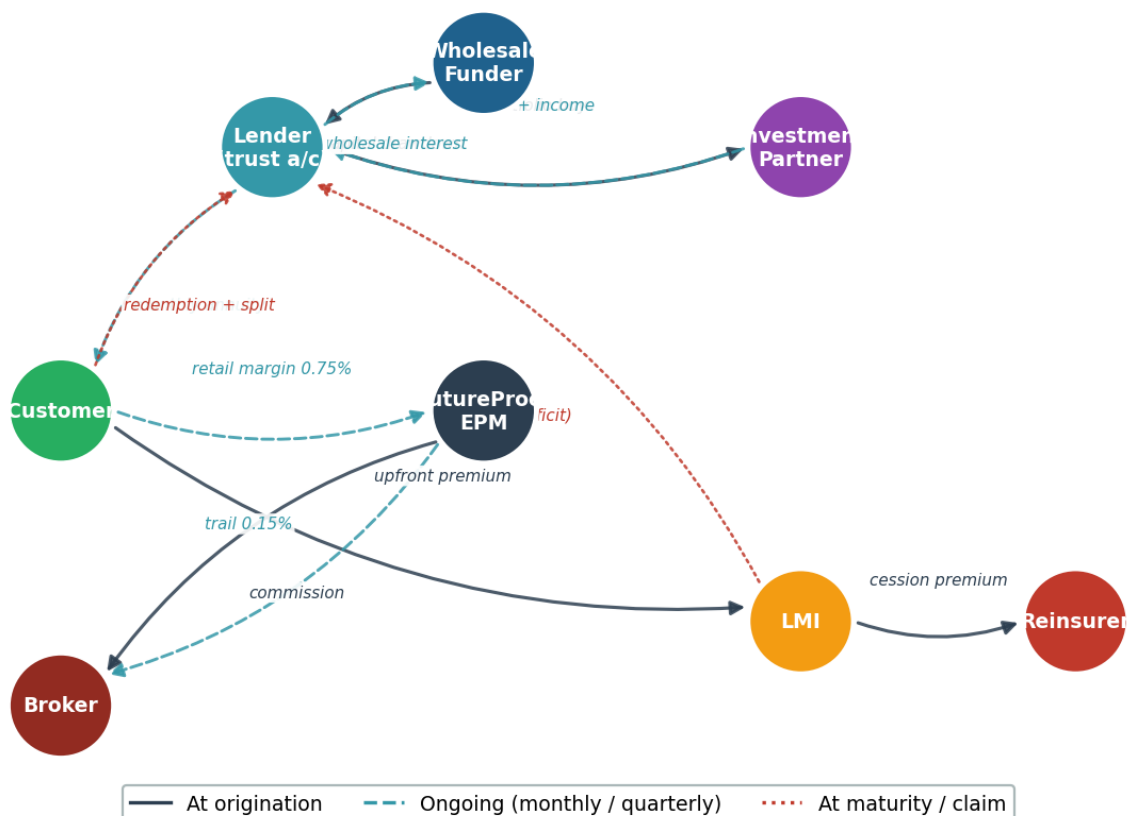
Admin — cross-cutting (weeks 1–28)

FutureProof Admin is not a single milestone. It evolves through every milestone: M0 ships the skeleton, M1 adds funder views, M2 adds lender views, M3 adds investment views, M4 adds insurance, M5 adds broker, M6 adds customer + CS console. Admin is authenticated, audit-logged, role-based. Every stakeholder group sees their own data; only FutureProof ops sees everything.

5. Money-Flow Map

Who pays whom, when. The diagram below shows the three stages of capital movement through the platform: at origination, ongoing, and at maturity / claim. Every arrow here corresponds to a reconciliation test in the milestone it is introduced; nothing in this diagram exists in the code without a test that proves the dollars end up on the right balance sheet.

Money-Flow Map — Origination, Ongoing, and Maturity



At origination (day 0)

- Wholesal funder draws down the facility amount to the lender's trust account. Reconciliation runs same-day.
- Lender invests the drawn-down capital with the Investment Partner — initial portfolio constructed per the ≈70% equity ETF / ≈30% fixed-income mix.
- Customer pays the upfront LMI premium directly to the LMI provider (not to FutureProof). LMI cedes a portion of the premium to the tail-risk reinsurer per the cession agreement.
- FutureProof remits the broker's upfront commission from its margin line, not from the customer.

Ongoing (monthly / quarterly)

- Investment Partner returns NAV and income to the lender — daily reconciliation, quarterly formal statement.
- Lender pays the customer the contracted monthly annuity.
- FutureProof accrues its 0.75% p.a. retail margin on the portfolio; debited monthly.
- Lender pays the wholesal funder monthly interest on the drawn-down facility.

- FutureProof accrues broker trail commission (0.15% p.a.) from its own margin.

At maturity / on claim

- Term maturity: property is sold or the customer redeems. Principal returned to the wholesale funder; any surplus split 80/20 between customer and FutureProof (per the Optimised model).
- Deficit scenario: LMI claim triggered against the deficit up to the LMI limit; excess above the LMI limit triggers a reinsurer claim at the P20 attachment point.
- Every path above has an acceptance test in M1 (funder), M3 (investment), or M4 (insurance/reinsurance). The test pack is authoritative over this narrative.

6. Go-Live Phase (weeks 28–32, ~AUD 35k)

Security, UAT, regulator, pilot. Four workstreams running in parallel. All four must be clean before the Go-Live gate closes.

- **External pen test** — independent firm, scoped to authenticated + unauthenticated app surface + partner integrations. Two weeks. AUD 15k. Remediation plan signed before gate.
- **Code audit + SOC 2 gap analysis** — external security consultant reviews the repo, CI, secrets, access controls. Documents the SOC 2 Type I gap (we will not be SOC 2 certified at pilot, but we need to know the gap). AUD 10k.
- **APRA / IRAP gap analysis** — documents the gap to APRA CPS 234 and IRAP readiness. Required for the Post-Live migration trigger decision. AUD 8k.
- **Stakeholder UAT** — one formal UAT round per stakeholder group. Fail criteria documented; pass criteria documented; sign-off is written.
- **Regulatory pack** — PDS, TMD, responsible-lending policy, disclosure documents. Filed.
- **Pilot cohort origination** — 5–10 mortgages through the live system. Paired origination (CTO + BA each oversees every case). Monthly reporting established.

Go-Live Gate: all seven stakeholder milestones gate-green, all four workstreams clean, board signs pilot go/no-go in writing. Any red is no-go.

6.1 Pilot success KPIs

"Pilot live" is not the same as "pilot successful." The board, wholesale funder, investment partner, and reinsurer each want numbers, not adjectives, on the pilot's performance. The table below is the pilot scorecard — measured monthly for the first six months post-Go-Live and reported back to every stakeholder group on a standing monthly cadence.

Metric	Target	Measurement
Origination volume	5–10 mortgages in first 6 months	Admin origination ledger
Application → quote funnel	≥ 30% of quotes progress to formal application	Funnel analytics in Admin
Quote calculator P90 latency	< 5 seconds customer-facing	Infra monitoring (Sentry / health checks)
Underwriting turnaround	< 5 business days, application to decision	Lender ops dashboard
E-sign completion rate	≥ 80% of customers who start e-sign complete	E-sign vendor telemetry
RG 271 complaint rate	< 5% of pilot cohort raise a formal complaint	IDR register
Funder reconciliation breaks	0 material breaks across the pilot	Daily funder reconciliation job
Investment-partner reconciliation breaks	0 material breaks across the pilot	Daily NAV / position reconciliation
P1 incidents (money-flow)	0	Incident register
P2 incidents (stakeholder-facing)	< 2 per month across the pilot	Incident register
Customer-facing uptime	≥ 99.5% monthly	Synthetic + real-user monitoring
Actuarial model-fidelity CI pass rate	100% on every production deploy	CI model-fidelity stage vs v14c golden vectors

A single red KPI does not kill the pilot — but two or more red in the same month triggers a board review, and three consecutive red months on any money-flow KPI triggers an automatic pause on new origination until resolved.

7. Post-Live — Operate & Evolve

The plan does not end at pilot origination. The Post-Live phase is named, budgeted, and governed. Run-rate ~AUD 200–240k / year for the 2-person team plus external retainers and infrastructure.

Post-Live Operate & Evolve Cycle



5.1 Release cadence

- **Monthly release** — the default. All non-emergency feature work, bug fixes, stakeholder-requested changes. Lane cadence: 3 weeks build + 1 week release (soak on staging, gate checks, release tag, deploy, smoke).
- **Emergency hotfix** — the exception. Used only for security or money-flow defects. Expedited gate path (G1–G5 still mandatory, G6 sign-off compressed to same-day). On-call engineer authors the fix; second person (CTO or BA, whoever is not on-call) signs.

5.2 Feature pipeline

New feature requests from any stakeholder go through the same scope → test → build loop as the original build. Features are sized by stakeholder group, prioritised quarterly by the board, and budgeted against the Post-Live run-rate. No stakeholder feature enters build without a signed scope brief. This is how the discipline of the stakeholder-gated MVP is preserved after go-live.

5.3 Change control for partner contracts

BlackRock, the lender, the reinsurer, and the e-sign vendor each have API contracts. When a partner announces a breaking change:

- Partner announces deprecation (typically 90 days notice).
- Engineer builds against the new contract in a feature branch. Fake is updated in lock-step.
- Contract tests green on the new contract; old contract tests still green until cutover.
- Cutover scheduled in the monthly release lane, coordinated with partner.

5.4 Model recalibration cycle

The v14c Optimised actuarial model has specific parameter assumptions ($\mu=9.2\%$, $\sigma=16.6\%$, $\kappa=0.163$). Those parameters are re-estimated annually via MLE on the latest index-return data. Re-estimation runs as a Python job against the `monte_carlo_v14c_optimised.py` simulator. The actuary countersigns the re-estimated parameters before they are adopted in the production pricing engine. Cycle: January each year. Actuary retainer: ~AUD 8k per cycle.

5.5 Security re-certification

- **Annual external pen test** — same firm ideally (continuity). AUD 15k per cycle.
- **Quarterly dependency refresh** — automated vulnerability scanning across all dependency managers. Clean or patched before the next monthly release.
- **Quarterly access review** — who has production access, who has partner-API credentials, who has admin role. Documented, signed by CTO.
- **Annual SOC 2 re-gap** — track the gap closing quarter by quarter. Full certification is a Series-A project, not Post-Live.

5.6 Incident model for a 2-person team

Paired on-call. One primary, one secondary, rotated weekly. External incident escalation retainer with a security consultant (AUD 5k / year). PagerDuty or equivalent for alerts. Runbook maintained alongside the code — a deploy without a runbook update for a new surface fails CI.

- **P1 (money-flow)** — funder drawdown fails, investment order fails, payment missed. Same-day response. Both engineers on the incident.
- **P2 (stakeholder-facing)** — customer cannot complete application, broker cannot lodge, admin cannot view. Same-day response.
- **P3 (internal)** — observability gap, non-urgent defect, documentation drift. Next-release response.

5.7 Infrastructure migration trigger

Fly.io → AWS ap-southeast-2 is event-triggered, not time-triggered. The event is the first wholesale-funder or reinsurer due-diligence questionnaire that requests IRAP attestation or APRA CPS 234 alignment evidence. That questionnaire typically lands after the first 20–50 mortgages are live and the counterparty is scaling its exposure. Until that point, Fly.io + Cloudflare is fit for purpose.

Migration is a named Post-Live project: ~6–8 weeks, ~AUD 45k (engineer time + AWS setup + IRAP-aligned architecture review + DNS cutover). Budgeted separately from the run-rate, triggered on the event. See section 11 for the full Fly.io assessment.

7.8 Scale-up path post-pilot

Pilot is 5–10 mortgages. The plan does not assume the team or the architecture stays two-person forever. The triggers below are volume-based, not calendar-based — they fire when book volume crosses the threshold.

Book size	Hiring trigger	Other changes
10 → 50 mortgages	No new hires	Partner reconciliation frequency doubles (daily → hourly at 50+). Post-Live pack rolls forward unchanged.
50 → 200	+ CS operator (full-time)	Broker accreditation extended to 20+ brokers. Second lender signed for geographic diversity. External actuary to quarterly review cadence.
200 → 500	+ Finance / ops lead	Second wholesale funder signed. AWS migration triggered (if not already). Automated APRA / ASIC reporting stood up.
500 → 1,000	+ Compliance / legal lead	SOC 2 Type I certification project. Broker network to 100+. Own AFSL + ACL application tabled at board.
1,000+	+ Second CTO (or CTO split)	Platform begins to look like a traditional non-bank lender. Series-B fundraise territory. Own licences live.

7.9 Business continuity & key-person

A 2-person team is a concentrated bus-factor risk. The containment is not a slogan; it is a documented set of controls that the board reviews annually.

- **Source-code escrow** with an AU-licensed escrow provider (e.g., NCC Group, Escrow Associates). Quarterly deposit of the main branch + build artefacts + runbooks. Release triggers: board resolution plus 30-day cure period.
- **Runbook coverage rule.** Every production surface must have a runbook that a non-author can execute in under one hour. Deploy of a new surface without an updated runbook fails CI. No exceptions.
- **Credential split.** CTO and BA each hold half of the privileged credentials (partner APIs, cloud roots, secrets manager). Neither can unilaterally lock out the other. On any departure, all credentials rotate within 24 hours.
- **Actuarial model handover.** The v14c Optimised Monte Carlo simulator + golden vectors live in-repo; reproducible from a clean checkout. No key-person dependency on the actuarial side.
- **Replacement lead-time assumption.** CTO replacement 3–6 months; BA 2–3 months. Board-approved retainer with a specialist financial-services tech recruiter shrinks the window to ~6–8 weeks on activation.
- **Fractional-CTO contingency.** If CTO departs mid-build, BA continues build and escalates architectural / partner-integration work to a fractional CTO retainer budgeted at AUD 20k for a 12-week bridge.
- **Cyber + professional indemnity insurance.** AUD 5M cyber cover + AUD 10M PI cover, policies maintained from Go-Live. Premium estimated at AUD 12k / yr, included in Post-Live run-rate under tooling / legal.

8. AI Leverage Across Business Operations

The same AI-first posture that drives delivery also drives the back office. Post-live, AI is a cost lever on every non-engineering function. We do not eliminate any of these functions — regulation, counterparties, and customers each require a human accountable — but we staff each function lighter than an equivalent financial-services business of our volume, because the human in each seat operates with AI as a force multiplier. The run-rate numbers in section 12 are calibrated on this assumption; the numbers below are the *implicit saving* versus a conventional staffing model.

8.1 Finance

- **Reconciliations drafted by AI, signed by finance.** Daily funder reconciliation, monthly investment-partner NAV reconciliation, quarterly reinsurer cession reconciliation — each runs as a scripted pipeline that produces a draft variance report plus the exceptions-only narrative. Finance spends time on exceptions, not tabulation.
- **Month-end pack drafted by AI.** P&L, balance sheet, funder utilisation, investment performance, insurance premium flow — drafted from the ledger, reviewed by the CFO-contractor retainer, signed by the CTO.
- **Budget vs actual variance analysis** drafted in minutes, not days.
- **Saving vs conventional model:** ~0.6 FTE of junior finance + ~0.3 FTE of senior finance review displaced by AI draft + contractor review. Estimated saved run-rate: ~AUD 90k / yr.

8.2 Operations

- **Monitoring triage.** Alerts routed through an AI classifier that summarises the event, cross-references the runbook, and produces a suggested action before paging a human. Human acks and acts; AI pre-digest compresses MTTR.
- **Runbook maintenance.** Runbook deltas drafted by AI from the CI diff, reviewed and merged by the CTO. No deploy lands without a runbook update; AI removes the tax that usually breaks this rule.
- **Vendor contract review.** BlackRock, funder, reinsurer, e-sign, ID verification — contract amendments are triaged by AI (change summary, risk flags, redline) before legal spends any billable hours.
- **Saving vs conventional model:** ~0.5 FTE of a dedicated ops coordinator. Estimated saved run-rate: ~AUD 60k / yr.

8.3 Customer Support

- **AI-first tier-1.** Tier-1 responses drafted, routed, and sent with a human CS operator signing. Complex cases escalated to actuary or legal with AI precedent search attached.
- **Case triage.** Incoming cases auto-classified (product question / servicing / dispute / complaint) with suggested response template; CS operator edits and sends.
- **Dispute drafting.** AI drafts the initial response packet (customer history, contract terms, actuarial context) for CS to review, so operators spend time on judgment, not search.
- **Saving vs conventional model:** pilot-phase CS can run with ~0.5 FTE instead of ~1.5 FTE for an equivalent volume. Estimated saved run-rate: ~AUD 80k / yr.

8.4 Marketing & Stakeholder Communications

- **Stakeholder decks** (board updates, funder reports, broker packs) drafted by AI from the underlying data; the BA edits the narrative and numbers.

- **Broker explainer materials** — FAQ updates, scenario walk-throughs, PDS-compliant marketing pages — drafted and compliance-checked against the legal glossary before human review.
- **Content pipeline** — blog, LinkedIn, media pitch — drafted by AI, human sign-off enforced before publish.
- **Saving vs conventional model:** ~0.4 FTE of content / marketing displaced by AI draft + BA edit. Estimated saved run-rate: ~AUD 55k / yr.

8.5 Where AI is explicitly *not* the answer

- Regulator-facing filings (PDS, TMD, RG 271 compliance statements) — drafted by legal, not AI.
- Underwriting decisions — deterministic rule-matrix; AI has no role in go/no-go on a specific mortgage.
- Model recalibration — actuary signs the parameter update; AI drafts the commentary only.
- Incident P1 communications — human author, human sign, no AI drafting on money-flow incidents.

8.6 Total implied operating saving

At steady state, AI leverage across finance, operations, customer support and marketing saves approximately AUD 285k / year versus a conventional staffing posture for a financial-services business of pilot size. That saving is the reason the Post-Live run-rate in section 12 is two-person rather than five-person. It is an *assumption* until operated; we commit to revisit the number at month 6 post-live and report the actual delta to the board.

9. Regulatory Pathway

FutureProof operates in Australia's consumer-credit + financial-services regulatory perimeter. The pilot runs under an existing retail lender's AFSL + ACL; own licensing is a post-pilot, volume-triggered decision, not a Day-1 requirement.

9.1 Licensing posture at pilot

- Pilot operates under the retail lender's **AFSL** (financial services) and **ACL** (credit). FutureProof is an *authorised representative* of the lender for dealing in the product.
- Own AFSL + ACL application is tabled at the board once volume crosses ~200 mortgages (see section 7.8). Driver is commercial and cost, not regulatory compulsion.
- ASIC notification of authorised-representative arrangement lodged at Go-Live.

9.2 Regulatory Guides that bind us

Reg. guide	Topic	How we comply
RG 271	Internal Dispute Resolution	30-day IDR response. IDR register maintained. AFCA reporting annual. Dispute-flow surface is authored in M6 and is authoritative.
RG 256	Client money	Any customer money held in trust is reconciled daily. Investment-Partner assets are NOT client money (lender holds legal title; customer has equitable interest).
RG 165	Licensing: financial advice	FutureProof does NOT provide personal advice. Calculator outputs are general product information; disclaimers reviewed by external legal.
RG 274	Product design and distribution (DDO)	TMD filed with PDS at Go-Live. Annual review; refresh on any material change. Tabled at the board.
RG 274 / NCCP	Responsible lending	Lender holds ACL. Rule matrix (M2) implements lender's responsible-lending framework; tests are ASIC-reviewable on request.

9.3 AML / CTF (AUSTRAC)

- Lender handles KYC / CDD under their existing AUSTRAC-registered AML programme. FutureProof inherits via the authorised-representative arrangement; our KYC data flows to the lender's MLRO for SMR triggers.
- Own AUSTRAC registration is a post-pilot item, tied to the own-licensing decision.

9.4 Privacy Act + Notifiable Data Breach

- APP-aligned privacy policy; external legal drafted and reviewed at M0.
- Consent captured per data purpose at application; revocation available self-service in customer portal.
- Right-to-access and right-to-correct surfaces in M6; 30-day SLA.
- **Notifiable Data Breach scheme:** breach assessment within 30 days; external breach counsel on retainer (tooling budget). Incident playbook integrated into the runbook.

9.5 Consumer Data Right (CDR)

Not in scope for pilot. Trigger to reconsider: first customer request for CDR export, or a counterparty requirement. CDR data-recipient accreditation is a Series-A project with a ~AUD 80k–120k project budget.

10. Data Governance

The most-asked funder and reinsurer due-diligence topic after "who is your hosting provider" is "who can see customer data and under what policy." The answers below are enforced in code and in runbooks, not just in policy.

10.1 Data residency

- All personal and financial data resides in ap-southeast-2 (Sydney) — Fly.io *syd* region at pilot; AWS ap-southeast-2 post-migration. No data crosses the AU boundary for storage.
- Processing is AU-only. AI/LLM calls that might touch regulated PII are routed through privacy-preserving abstractions (PII redacted or tokenised before the prompt leaves our VPC).

10.2 Encryption

- At rest: native database encryption + column-level envelope encryption for regulated-tier PII (per-row keys, keys managed in the secrets manager).
- In transit: TLS 1.3 on all ingress; mTLS to all counterparty APIs (funder, Investment Partner, LMI, e-sign, ID verification).
- At application: bcrypt / Argon2 for credentials; never plaintext; never in application logs.

10.3 PII tiers

Tier	Examples	Controls
Public	Marketing pages, public PDS	No special controls.
Restricted	Customer application data, contact details, contract terms	DB encryption at rest; authenticated access only; audit-logged.
Regulated	ID documents, credit history, financial statements	Column-level encryption with per-row keys; every read logged to the immutable audit trail; access gated by CTO-signed role.

10.4 Retention & deletion

- Retention: 7 years post-contract-close (ATO and NCCP standard). Retention clock starts on the later of contract close and last customer interaction.
- Automatic hard-delete scheduler runs annually; deletes regulated-tier PII past retention; retains anonymised aggregates for actuarial purposes.
- Customer-initiated deletion: processed within 30 days, subject to overriding legal retention obligations.

10.5 Audit log

Every read of regulated-tier PII is logged (who, when, from where, for what stated purpose). Jurisdiction-aware audit logging is applied uniformly across every PII read-path. Audit log is append-only, retained for the full retention period, and queryable only by CTO for incident or regulator response.

10.6 Data-subject requests

30-day SLA for access, correction, and deletion requests. Self-service for simple access/correction via customer portal; manual requests handled by CS with CTO sign-off on deletion.

11. Infrastructure — Fly.io for financial services

Fly.io is the right partner for the MVP and pilot. It is not the right partner at scale. The migration trigger is event-based, not time-based.

11.1 Why Fly.io is fine for the MVP

- SOC 2 Type II compliant.
- Sydney region (syd) available — data residency controllable at the application level.
- Proven at our volume with the web framework and database we run on.
- Fast rollback (fly releases rollback) — important for a 2-person team.
- Low ops burden — a 2-person team cannot operate a full AWS estate without dedicated DevOps.
- Pricing is transparent and cheap at pilot scale (dozens of mortgages, not thousands).

Pair with:

- **Cloudflare** in front of Fly.io for WAF, DDoS, rate-limit, bot mitigation, and a stable edge IP for partner-allowlisting.
- **AWS S3** (already in use) for backups and document storage — gives a credible exit ramp.
- **1Password / Doppler** for secret management outside the repo.

11.2 Why Fly.io is not right at scale

- No APRA CPS 234 attestation.
- No IRAP rating.
- Wholesale-funder due diligence under APRA CPS 231 (material outsourcing) will demand enterprise-grade hosting once the book is material — typically after the first 20–50 mortgages.
- Limited enterprise networking primitives (no PrivateLink-equivalent, limited VPC isolation) vs AWS ap-southeast-2.
- Limited data-residency contractual controls compared to AWS's enterprise agreements.
- Reinsurer due-diligence is similar — the moment the reinsurer wants evidence of the underlying hosting's compliance posture, Fly.io becomes the conversation problem, not the technology problem.

11.3 Migration plan (budgeted, not executed at MVP)

The migration itself is not difficult. The platform has no Fly-specific primitives beyond the deploy command and secrets.

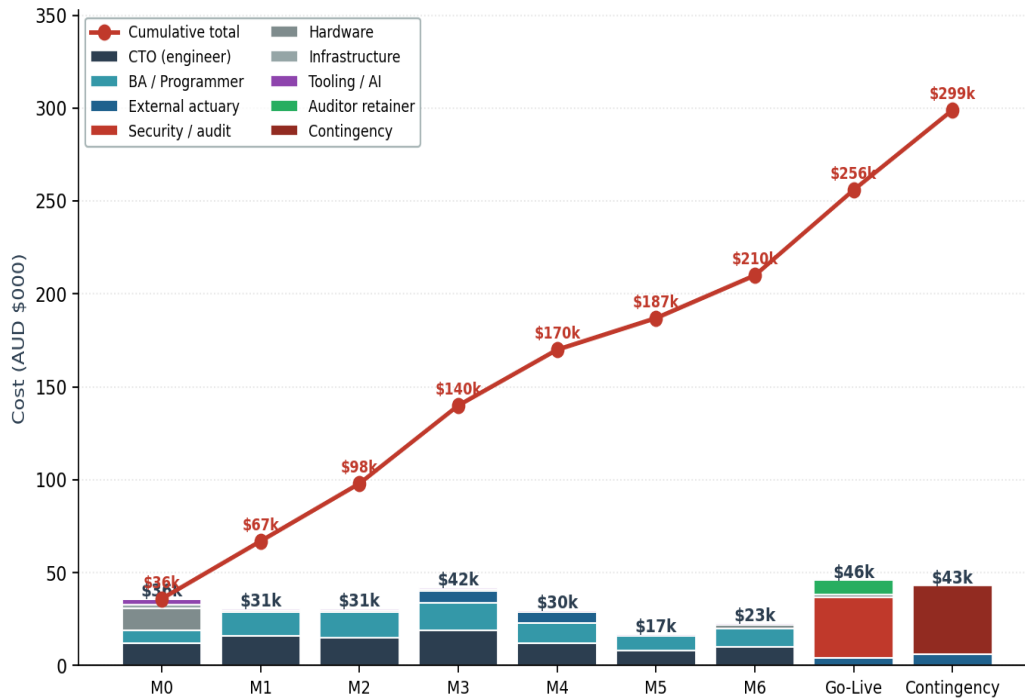
Step	Duration	Cost
1. IRAP-aligned architecture review (independent consultant)	1 week	AUD 8k
2. AWS ap-southeast-2 VPC + ECS/Fargate + managed database + CloudFront setup	2 weeks	engineer
3. Dual-running period with cutover testing on staging	2 weeks	—
4. DNS cutover with rollback plan	1 day	—
5. Post-cutover monitoring + Fly.io decommission	1 week	—
Total	6–8 weeks	~AUD 45k

Triggered on the first counterparty questionnaire, not on a calendar date. Named in the Post-Live budget as a separate line.

12. Costs & Capital Ask

Itemised build cost in AUD. External legal (contracts, PDS, broker accreditation, funder agreements, AFSL / ACL work) is governed by a separate legal budget and does not appear here. Post-Live run-rate, the event-triggered migration reserve, and an operational buffer are separate lines and are not bundled into the headline build number.

Cost Waterfall — Build Budget by Milestone (Total ≈ AUD 285k inc. contingency; legal budgeted separately)



12.1 Build budget

Line item	AUD	Notes
CTO (30 wks @ 160k annualised)	92,000	Market-rate CTO
BA / Programmer (30 wks @ 140k × 0.8 FTE)	65,000	Scope-test-build per stakeholder is BA-intensive
External actuary (4 reviews)	22,000	M3, M4, Go-Live, Post-Live kickoff
Security (pen test + SOC 2 gap + APRA/IRAP gap)	33,000	15k + 10k + 8k
Auditor retainer (pilot period)	8,000	
Hardware (laptops, dev kit, HSM-grade token)	15,000	2× dev machines + YubiKeys + ergonomic setup
Infrastructure	5,000	Fly.io + Cloudflare + monitoring + AWS backup
Tooling SaaS	4,000	CI, e-sign, ID verification, error tracking
AI / LLM spend (Claude API for BA workflow)	4,000	
Subtotal	248,000	
Contingency (15%)	37,000	
Total with contingency	285,000	Headline: ~AUD 285k (legal separate)

12.2 Post-Live annualised run-rate

Line item	Annual AUD
CTO (full year)	160,000
BA / Programmer (0.8 FTE)	112,000
External actuary (annual recalibration)	8,000
Annual pen test	15,000
Infrastructure	12,000
Tooling SaaS	8,000
AI / LLM spend	8,000
Cyber + PI insurance (see 7.9)	12,000
Total annualised	~335,000 (range 325–360k)

Implied operating saving via AI leverage (section 8): ~AUD 285k / yr versus a conventional staffing model — the reason the Post-Live line is two-person, not five. Legal retainer sits in the separate legal budget.

12.3 Capital ask (build + 12-month runway)

The capital ask is layered so the board can see which dollars are contractual, which are event-triggered, and which are buffer. Legal spend is funded from the separate legal budget and is outside this ask.

Layer	AUD	Purpose
Build budget (this section, row-total)	285,000	30-week delivery to pilot-live
Post-Live — Year 1 run-rate	335,000	Two-person team + infra + insurance + recertification
Infrastructure migration reserve (Fly.io → AWS)	45,000	Event-triggered; held in reserve, not drawn at day 1 (\$11.3)
Operational / regulatory contingency buffer	35,000	~5% of first three lines — covers AUSTRAC onboarding, unplanned due-diligence rounds
Total capital ask	~700,000	Runway: build + 12 months post-live + migration cover

Headline capital ask: AUD 700k. Build + one year post-live + named migration reserve + buffer. Legal is separately budgeted. Any Series-A decision is a separate conversation after pilot completes.

13. Risks & Unknowns

Risk	Owner	Mitigation
BlackRock not signed by M3 start (week 11)	BA	Plan-B: domestic managed-account provider via the Investment Partner Interface abstraction. ~4 weeks additional work.
Wholesale funder not signed by M1 start (week 5)	BA	Approach 3 funders in parallel from week 1. Fake-first architecture means build continues.
Regulatory surprise (PDS, TMD, responsible lending)	BA + Legal	External legal engaged week 1; informal regulator approach before formal filing.
Reinsurer rejects P20 attachment	Actuary + BA	Present v14c Optimised actuarial review early (week 14); iterate on attachment if challenged.
Solo-engineer bus factor	CTO	BA is a programmer, not just a liaison; paired on-call; external code review at each gate.
Scope creep from signed briefs	BA	Signed briefs are immutable; changes require re-sign; budget 3 rounds per milestone.
Infrastructure migration triggered mid-pilot	CTO	Named project, pre-priced, pre-scoped. Execute in the 6–8 week window without blocking new origination.
AI code quality regression	CTO + BA	CTO reviews every BA-generated PR; contract tests and acceptance tests are authoritative, not AI suggestions.
AI back-office saving does not materialise	CTO + BA	Revisit at month 6 post-live; report actual delta to board. Staffing uplift is a Series-A decision if AI leverage falls short of the 285k/yr assumption in section 8.

14. Go / No-Go Criteria for Pilot

All of:

- All seven stakeholder milestones gate-green.
- External pen test clean or remediated.
- SOC 2 + APRA/IRAP gap documents filed and reviewed by board.
- PDS + TMD filed.
- 5–10 pilot customer intents signed.
- Funder, BlackRock (or Plan-B), LMI, reinsurer, and pilot brokers all countersigned their integration test reports.
- CTO and BA both recommend go in writing.
- Board approves in writing.

Any red is no-go. No exceptions.

Appendix A — Companion Document

- **v14c Optimised Actuarial Review (April 2026)** — the model that pricing, LMI attachment, and reinsurance cession inherit from. Every model-fidelity test in this plan pins to its locked output.